基于 Isabelle/HOL 的 VWZ 后量子密码协议
形式化验证与规范缺陷分析

刘天赫

独立研究者

research@fibemate.net

2026 年 10 月

摘要

后量子密码实现涉及模算术、矩阵代数与采样器，仅靠测试无法保证其数学陈述正确。本文用 Isabelle/HOL 对后量子构造（VWZ）的代数骨架与协议对象建模，并坚持一条纪律：先按原文形式化，机器否证后才允许改述。依此在规范中发现四处缺陷：算术域错配（`T2_B3`）、零化度口径错配（`T2_D4`），以及两处前提缺失致陈述为假（`T2_B7` 缺秩前提、`T2_D5` 迫使目标位与消息无关）。前两处给出改述与闭合证明；后两处给出三行以内的机器反证，并区分两类不可证原因：缺数学、缺建模决策。系统含 20 个理论文件、56 条义务引理（余 7 个未闭合，账本外零个 `sorry`），构建约 16 秒。本文的贡献在于：形式化能在实现之前把” 看起来对” 的句子变成” 机器判定为假” 的句子。

关键词：后量子密码；形式化验证；Isabelle/HOL；规范缺陷；矩阵代数

1 引言

1.1 研究背景

后量子密码标准的落地（如美国 NIST 于 2024 年发布的 FIPS 203 与 FIPS 204[1, 2]）使大量系统在短时间内需要完成算法替换 [4]。替换过程中的风险并不只在算法本身，也在围绕算法写下的数学陈述：密钥生成是否真的产生可逆矩阵、采样器输出的支撑集大小是否等于设计参数、签名验证所比较的量是否真的依赖于消息。这些问题在散文层面极易被” 显然” 或” 按设计” 带过，而一旦实现与陈述之间存在错配，测试通常无法发现——测试只能证明某些输入下行为一致，不能证明陈述为真。

1.2 动机：自证陷阱

作者在实践中遇到的最主要障碍不是证明难度，而是自证陷阱：用自己写的解析器验证自己生成的输出，用自己写的测试验证自己写的实现。这类验证在逻辑上是同义反复。打破循环的唯一方式是引入外部参照——对代码是独立实现与官方 schema，对数学陈述则是交互式定理证明器：它不接受” 按设计应当如此”，只接受能闭合的证明树。这一思路在系统层与实现层已有成熟先例：seL4 内核的完整功能正确性证明 [7]、Jasmin 的经过验证的编译器与常量时间检查 [8]、HACL* 的经过验证的密码库 [9]；计算机辅助密码学的整体版图见文献 [10]，而在后量子方向，EasyPQC 已把具体安全性证明扩展到量子敌手模型 [11]。本文的工作与上述方向互补：不针对实现代码，而针对规范中的数学陈述本身。

1.3 本文贡献

1. 在一个真实的后量子构造（VWZ）上建立了可复跑的形式化骨架：20 个理论文件、56 条分层义务引理、账本外零个 `sorry`。
2. 发现并机器否证了四处规范缺陷，其中两处给出了可证的改述并已闭合。
3. 提出并实践了” 形式化—否证—改述” 四步法（第 4.5 节），把” 改述” 从一种可以随手进行的便利，变成必须有机器证据才能执行的动作。
4. 给出完整的复现路径：一条构建命令、一条账本统计命令，全部缺陷均可被第三方重跑。

2 预备知识与形式化基础

2.1 Isabelle/HOL

Isabelle/HOL 是一个基于高阶逻辑的交互式定理证明器 [3, 6]。本文使用 Isabelle2025-2，所有定义与证明均以结构化证明语言 Isar 书写，构建会话为 `VWZ_A3_Aligned`。选择 Isabelle/HOL 的两个实际理由：其一，它的列表与矩阵库足以承载本文所需的有限维线性代数；其二，它的 `quick_and_dirty` 模式允许在开发期保留未闭合证明并显式计数，这使” 还剩几个 `sorry`” 成为一个可查询的指标，而不是口头承诺。

2.2 域 $\mathbb{F}_{3329}$ 与矩阵代数

素数 $q = 3329$ 由 `by eval` 机器验证。域元素取 $\{0, \ldots, 3328\}$，归约函数定义为 `fq x = x mod 3329`。矩阵类型为 `int list list`，向量类型为 `int list`；这一选择使” 模 q” 与” 整数” 两种口径可以共存，也正是第 4 节第一处缺陷得以暴露的原因。

本文刻意区分两个矩阵乘法：mat_mult（整数点积，不归约）与 mat_mult_mod（点积后过 fq）。二者在 $\mathbb{Z}$ 上不同，在 $\mathbb{F}_{3329}$ 上一致；混淆二者是一条真实的规范缺陷。

2.3 行化简与燃料参数化

行化简 rref 采用燃料（fuel）参数化，从而避免终止性证明：rref_fuel f r c A 在燃料耗尽或扫描越界时返回当前矩阵。秩定义为化简后非零行的个数：

$$\texttt{mat_rank A} = \texttt{length (filter } \lambda r.\ \neg\, \texttt{all_zero_row } r\ \texttt{(rref A))}.$$

零化度给出两种口径：行口径 dim_nullspace A = n_rows A - mat_rank A 与列口径 nullity A = n_cols A - mat_rank A。对方阵二者一致，对非方阵则相差一个维数——这是第 4 节第二处缺陷的来源。

3 VWZ 协议的形式化建模

3.1 数据模型与序列化

公钥与私钥以记录形式建模（pkey、skey、sigrec），序列化与反序列化沿用规范第 8.3 节的字段顺序；长度字段按小端 16 位处理。建模原则是” 规范写了什么就写什么”：若规范未固定某一顺序，则在注释中标注为自由，不在证明中悄悄利用该自由度。

3.2 关键子模块

- **密钥生成。** KeyGen 按规范第 3.3 节的抽签顺序实现：先取两个 λ 向量，再取四个矩阵 $X_{2a}, X_{2b}, X_{3a}, X_{3b}$，最后取 x_1。可逆矩阵由 rim_iter 从单位阵出发执行 m^2 次” 把一行的倍数加到另一行” 得到，轮数由结构决定，不额外引入燃料。
- **目标向量。** hash_target 先由摘要载体给出随机字序列，再用原地交换式的部分 Fisher–Yates 走步（fy_fuel 与 swap_at）从全体位置中抽出 $k+1$ 个互异位置，最后取这些位置的指示向量。唯一未解释的原语是 digest（XOF），本文不对它作任何密码学假设，并且明确保留前提” 摘要至少提供 $k+1$ 个字”，否则该命题为假。
- **求线性方程组。** solve_linear 以 Hilbert 选择算子给出规格化定义：若存在满足模 q 方程组的解则返回其一，否则返回 None。它明确是 specification 而非可执行算法，Gauss–Jordan 回代作为欠账记录在案。

3.3 义务账本

义务按四层组织：T0（纯形式重写，17 条）、T1-A（代数公理层，16 条）、T1-D（依赖定义层，5 条）、T2（线性代数与矩阵，10 条）、T3（安全性与解析器，8 条），合计 56 条。账本由脚本统计而非人工申报；同时统计” 账本之外的 sorry”，当前为 0。这一约束的实际意义是：任何为了凑数而新增的未闭合引理都会立刻被统计暴露。

4 规范缺陷的发现与修正

本节四条缺陷均按同一流程处理：按原文形式化 $\to$ 尝试证明 $\to$ 若失败则构造机器反例 $\to$ 反例成立后才改述。改述一律记录原文与理由，不静默弱化。

4.1 域错配：整数环与模 q 环（T2_B3）

原文陈述。密钥生成中的行操作与矩阵代数之间的桥接，写作” 存在整数意义下的双边逆”，即 `invertible (X2a_of m s)`。

为何为假。 `add_row_mult` 对每个元素做模 3329 归约，而 `mat_mult` 计算未归约的整数点积。二者相差一次归约，且归约后的矩阵在 $\mathbb{Z}$ 上根本不可逆。

机器证据。在 `VWZ_Probe.thy` 中：

$$\texttt{mat_mult (row_add_matrix 2 0 1 1) [[1,3328],[0,1]]} = \texttt{[[1,3329],[0,1]]},$$
$$\texttt{add_row_mult [[1,3328],[0,1]] 0 1 1} = \texttt{[[1,0],[0,1]]}.$$

两次行加之后，结果矩阵的整数行列式为 -998699：模 q 为 1，在 $\mathbb{Z}$ 中则不是单位。

处置（已闭合）。将义务改述到 $\mathbb{F}_{3329}$：以 `mat_mult_mod` 定义模乘法，以” 存在形状合格的见证 B，使两个乘积与单位阵同余” 定义可逆性（`cong_q_mat`）。此处必须用同余而非等号：`mat_mult_mod` X (`id_mat` m) = `map (map fq)` X，仅当 X 已归约时才等于自身，而见证是任意的。改述后该义务获得机器证明。

注 1. *这条缺陷在散文中极难发现：规范把”模 q”写在算法描述里，把”可逆”写在数学论证里，两者从未在同一句话中相遇。形式化强迫它们相遇。*

4.2 维数错配：行零化度与列零化度（T2_D4）

原文陈述。对 $k \geq 2$，`dim (nullspace (rows3))` $\geq k-1$，其中零化度按行口径 `dim_nullspace A = n_rows A − mat_rank A` 计算。

为何为假。 `rows3` 是 $(k+2) \times (2k+1)$ 的系统。行口径给出 $k+2-\texttt{rank}$，要求它 $\geq k-1$ 等价于要求每个此类系统满足 $\texttt{rank} \leq 3$，这显然不成立，也不是采样器真正需要的性质。

正确定式。论证真正需要的是列映射的零化度：

$$\texttt{nullity A} \;=\; \texttt{n_cols A} - \texttt{mat_rank A} \;=\; 2k+1-\texttt{rank},$$

只要 rank $\le k+2$（即化简保持行数）即得 $\ge k-1$。

处置（已闭合）。新增 nullity 而不改动 dim_nullspace （后者在方阵上是正确口径，已有小例引理不受影响）；同时为 rows3_of 补上规范第 6.4.1 节给出的函数体（Z_a 部分取 λ_c 的 Vandermonde 行，Z_b 部分取 M_3^{T} 行），使义务具备其陈述真正依赖的四个参数。改述后该义务获得机器证明。

4.3 秩前提缺失（T2_B7）

原文陈述。对任意公钥 pk 与范围内下标 i，mat_rank (psi_slice pk i) $= 2$。

为何为假。 i < length (pk_psi pk) 只是记录形状约束，它不排除切片为零矩阵。形状正确、切片为零的公钥，其秩为 0。

机器证据。在 VWZ_Refutations.thy 中给出具体公钥与 T2_B7_counterexample（秩为 0），并以 T2_B7_refuted 证明" 对任意公钥与下标，切片秩恒为 2" 的否定。

改述与状态。补三条前提：(1) 公钥属于 KeyGen 的像；(2) 切片存在非零 2×2 子式（对两个外积之和而言，即两个抽取向量不平行）；(3) 下标在范围内。改述后的陈述为真且已入账，但**尚未证明**：它需要一套本系统尚无的行空间秩理论。已完成的首层（VWZ_Rank.thy）给出外积与其和的形状、入口公式，以及" 零矩阵的秩为零"——后者是经由 rref 证明的真命题，而非定义展开。尚缺四块：

1. rref_step：交换行、行乘单位、行加倍数各自是左乘一个可逆矩阵；
2. minors_invariant_under_row_ops：行操作保持" 所有 2×2 子式为零"；
3. rank_le_one_imp_minors_vanish：至多一个非零行的化简形不含非零子式；
4. mat_rank (mat_mult A B) $\le$ n_cols A，即秩不超过主元列数。

4.4 目标独立性冲突（T2_D5）

原文陈述。若 i 落在目标支撑集内，则

$$\texttt{Eval pk w2 w3 ! i} \;=\; \texttt{hash_target k msg ! i},$$

其中 pk、w2、w3、k、msg 全部自由。

为何为假。求值函数的类型是 Eval : nat list ⇒ nat list ⇒ nat list ⇒ nat list——它既不接收 k，也不接收 msg。于是同一组求值参数配合两条不同消息时，左端是同一个项，右端是两个不同的目标位。

机器证据。 VWZ_Refutations.thy 中的 T2_D5_forces_target_independence：若下标同时落在两条消息的支撑集内，则两位目标位相等。证明仅三行：把求值参数实例化为空列表，两次套用该义务即得同一项等于两个不同的位。该证明不使用任何关于 digest 的假设，因此这是措辞缺陷而非密码学困难。

缺失的三项（当前不可补）。 (1) 签名函数 Sign 的函数体；(2) 联结前提：公钥是签名者的公钥、两个见证是 Sign 为该消息产出的一对；(3) 一个能够消费摘要的求值函数。在签名语义未定之前补这三项，等价于用定义掩盖结论，本文明确拒绝。

4.5 缺陷发现的四步法

1. **照抄形式化**：义务的每个前提与结论逐字转写，不补” 显然” 的前提，不弱化量词范围。
2. **先证后猜**：只有当证明确实无法闭合时，才开始寻找反例；反之亦然，禁止” 因为证不出来所以改陈述”。
3. **反例入账**：反例必须是机器可检的具体对象（具体矩阵、具体下标），并放在义务账本之外，避免” 关掉缺陷” 提高引理数。
4. **改述留痕**：改述必须记录原文、理由、以及” 为什么在这个更强的前提下命题为真”。

这四步的成本很低，但它把” 改述” 变成了一个有门槛的动作：没有机器证据，就不许改。

5 实验与可复现性

5.1 工具链

Isabelle2025-2；构建会话 `VWZ_A3_Aligned`（父会话 `HOL-Number-Theory`，选项 `quick_and_dirty`）；在 64 位 Windows 上通过 Cygwin 驱动；全量构建 `isabelle build -D aligned -o document=false`。

5.2 量化数据

表 1: 系统规模与验证指标

指标	数值
理论文件数	20
仓库内引理总数	373
账本内义务引理	56
账本内未闭合证明（`sorry`）	7
账本外未闭合证明	0
全量构建耗时	约 16 秒
已闭合缺陷	2（`T2_B3`、`T2_D4`）
已机器否证、待改述闭合的缺陷	2（`T2_B7`、`T2_D5`）

5.3 复现指南

```
isabelle build -D aligned -o document=false   # 期望 RC=0，约 16 秒
```

```
node tools/count-obligations.cjs
# 期望输出：56 lemmas, 7 sorry, outside 0
```

反例文件 VWZ_Refutations.thy 参与同一会话构建，因此本文引用的每一条否证都在每次构建时被重新检查，不存在”当年跑过一次”的证据。

6 局限性与展望

6.1 未完成的建模

签名与求值仍是未解释原语。这不是疏忽，而是刻意的边界：一旦给出函数体，就必须同时固定协议语义与安全性假设，而这会改变本文的论断范围。本文选择先把可判定的部分判定完，再把不可判定的部分明确标注出来。

6.2 缺失的秩理论层

T2_B7 的改述已为真，但其证明依赖行空间理论（第 4 节 4.4）。预计需要两到三个工作周期完成。在此之前，本文不声称该条已证。

6.3 下一步工作

其一，补全秩理论并闭合 T2_B7；其二，建立签名语义后改述并检查 T2_D5；其三，把”形式化—否证—改述”流程沉淀为可复用的检查清单，使其可迁移到其他后量子构造的规范评审中。

7 结论

本文在一个真实的后量子构造上证明了形式化验证的一种具体价值：它不仅能证明对的陈述，还能在实现之前把错的陈述判为假。四处规范缺陷中，两处经改述后可证并已闭合，两处被三行以内的机器反证击穿。系统规模不大（56 条义务引理），但每一条都可复跑、可审查、可追溯。比起引理数量，本文更看重的是那条纪律：*没有机器证据，就不许改述。*

参考文献

[1] National Institute of Standards and Technology. *FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard*. 2024.

[2] National Institute of Standards and Technology. *FIPS 204: Module-Lattice-Based Digital Signature Standard*. 2024.

[3] T. Nipkow, L. C. Paulson, M. Wenzel. *Isabelle/HOL: A Proof Assistant for Higher-Order Logic*. LNCS 2283, Springer, 2002.

[4] D. J. Bernstein, T. Lange. Post-quantum cryptography. *Nature*, 549:39–41, 2017.

[5] VWZ 规范文档（内部稿）：`security-assessment/…/vwz-fix-mixed-tensor.md`.

[6] L. C. Paulson. *Isabelle: A Generic Theorem Prover*. LNCS 828, Springer, 1994.

[7] G. Klein, K. Elphinstone, G. Heiser, J. Andronick, D. Cock, P. Derrin, D. Elkaduwe, K. Engelhardt, R. Kolanski, M. Norrish, T. Sewell, H. Tuch, S. Winwood. seL4: Formal Verification of an OS Kernel. *Proc. 22nd ACM Symposium on Operating Systems Principles (SOSP)*, 2009: 207–220.

[8] J. B. Almeida, M. Barbosa, G. Barthe, A. Blot, B. Grégoire, V. Laporte, T. Oliveira, H. Pacheco, B. Schmidt, P.-Y. Strub. Jasmin: High-Assurance and High-Speed Cryptography. *Proc. ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2017: 1807–1823.

[9] J.-K. Zinzindohoué, K. Bhargavan, J. Protzenko, B. Beurdouche. HACL*: A Verified Modern Cryptographic Library. *Proc. ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2017: 1789–1806.

[10] M. Barbosa, G. Barthe, K. Bhargavan, B. Blanchet, C. Cremers, K. Liao, B. Parno. SoK: Computer-Aided Cryptography. *Proc. IEEE Symposium on Security and Privacy (S&P)*, 2021: 777–795.

[11] M. Barbosa, G. Barthe, X. Fan, B. Grégoire, S.-H. Hung. EasyPQC: Verifying Post-Quantum Cryptography. *Proc. ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2021.

A 缺陷索引与机器证据

表 2: 四处缺陷的定位与证据

义务	缺陷类型	机器证据	状态
T2_B3	按 $\mathbb{Z}$ 陈述，实现按 $\mathbb{F}_{3329}$ 归约	probe_mult、probe_rowop（VWZ_Probe.thy）	改述后已闭合
T2_D4	非方阵系统误用行零化度	算术：$k+2-\mathtt{rank} \geq k-1$ 需 $\mathtt{rank} \leq 3$	改述后已闭合
T2_B7	秩为 2 的断言缺良构前提	T2_B7_counterexample、T2_B7_refuted	已改述，待秩理论
T2_D5	目标位被强制与消息无关	T2_D5_forces_target_independence	待签名语义